

**Implementación de un sistema de detección de ataques utilizando logs y registros en un
entorno simulado**

**Henao Gutiérrez William Samuel, Jurado Londoño Wendy Daniela, Minotta Andrade
Harold Alberto**

Fundación Tecnológica Autónoma del Pacífico

Facultad de Ingeniería de Sistemas

Santiago de Cali xx 10 de 2024

Nota del Autor

**Este Informe del Curso de Grado Actualización en Ciberseguridad se realizó como
requisito para optar al Título de Tecnólogo en Ingeniería de Sistemas y fue asesorado por
el Senior Pentester Edward Steven Osorio Soto**

**La correspondencia referida a este documento debe dirigirse a Henao Gutierrez William
Samuel, Jurado Londoño Wendy Daniela, Minotta Andrade Harold Alberto, dirección
electrónica: william.henao.0ds@utap.edu.co, wendy.jurado.0ds@utap.edu.co,
harold.minotta.0ds@utap.edu.co**

Resumen

Se ha implementado y evaluado un sistema de detección de intrusiones (IDS) personalizado. El enfoque se centra en identificar y mitigar amenazas cibernéticas en un entorno controlado mediante la selección de una plataforma IDS adecuada y la configuración de reglas de detección personalizadas. Los resultados de las pruebas de simulación permitirán evaluar la eficacia del sistema y proponer mejoras para optimizar su funcionamiento.

Palabras clave: IDS, detección, logs, ataques, implementación

Abstract

A customized intrusion detection system (IDS) has been implemented and evaluated. The focus is on identifying and mitigating cyber threats in a controlled environment by selecting a suitable IDS platform and configuring customized detection rules. The results of simulation tests will allow evaluating the effectiveness of the system and proposing improvements to optimize its performance.

Keywords: IDS, detection, logs, attacks, deployment

Contenido

pág.

Introducción	5
Objetivos	6
Objetivo General	6
Objetivos Específicos	6
Justificación	7
Identificación y Selección de una Plataforma IDS	8
Selección de una plataforma IDS	8
Plataformas IDS	9
Diseño e implementación de una solución IDS personalizada	10
Pruebas de simulación	19
Configuración, operación y resolución de problemas comunes del IDS	21
Manual de Usuario del IDS OSSIM	21
Índice	21
Introducción	21
Requisitos Previos	21
Instalación del IDS OSSIM	21
Configuración Inicial	22
Configuración del Sensor IDS	22
Monitorización y Operación del IDS	23
Resolución de Problemas Comunes	23
Mantenimiento del IDS	23

DET. ATAQUES C/LOGS	4
---------------------	---

Conclusiones	24
---------------------	-----------

Recomendaciones	25
------------------------	-----------

Referencias	26
--------------------	-----------

Apéndices	27
------------------	-----------

Introducción

Los sistemas de detección de intrusos (IDS) juegan un papel fundamental en la protección de redes y sistemas, al identificar comportamientos anómalos y potenciales amenazas mediante el análisis de logs y registros de actividad. ¹Sin embargo, la configuración y adaptación de estos sistemas a entornos específicos sigue siendo un desafío.

La seguridad de la información es una preocupación constante. Los ataques cibernéticos están en aumento, el análisis de datos de junio de 2022 a julio de 2023 y de junio de 2021 a julio de 2022 revela que los ataques de malware contra computadoras y dispositivos móviles en América Latina han experimentado un aumento del 617² y las organizaciones necesitan estar preparadas para proteger sus sistemas y redes contra intrusiones no autorizadas.

¹ Whitman, M. E., & Mattord, H. J. (2017). Principles of Information Security (6th ed.). Cengage Learning

²<https://latam.kaspersky.com/about/press-releases/nueva-epidemia-el-phishing-se-sextuplico-en-america-latina-con-el-reinicio-de-la-actividad-economica-y-el-apoyo-de-la-ia>

Objetivos

Objetivo General

Implementar un sistema funcional de detección de ataques mediante el análisis de logs y registros en un entorno controlado, con el propósito de identificar y mitigar amenazas potenciales de manera eficaz, evaluando su rendimiento y precisión en la identificación de eventos sospechosos.

Objetivos Específicos

- Identificar y seleccionar una plataforma IDS, considerando factores como análisis de logs, escalabilidad, funcionalidad, rendimiento, disponibilidad, seguridad e integración.
- Diseñar e implementar una solución IDS personalizada, integrando múltiples fuentes de datos y configurando reglas de detección adaptadas a las amenazas más relevantes.
- Evaluar la efectividad del IDS mediante la simulación de una variedad de ataques cibernéticos, evaluando su capacidad de detectar y alertar sobre incidentes de seguridad en tiempo real.
- Analizar los resultados obtenidos de las pruebas de simulación para identificar las fortalezas y debilidades del sistema de detección, así como proponer mejoras para optimizar su funcionamiento.
- Elaborar un manual de usuario detallado que guíe a los usuarios en la configuración, operación y resolución de problemas comunes del IDS, facilitando su integración y mantenimiento.

Justificación

La implementación de un sistema de detección de intrusiones resulta fundamental en el actual panorama de ciberseguridad. En un entorno donde las amenazas evolucionan constantemente y los ataques se vuelven cada vez más sofisticados, contar con herramientas eficaces se vuelve imperativo (Buczak & Guven, 2016). Por lo tanto, este proyecto se justifica plenamente debido a la necesidad apremiante de proteger los activos de información y salvaguardar la integridad de los sistemas informáticos. Considerando factores como el análisis de logs, escalabilidad y rendimiento, es crucial, ya que determinará la capacidad del sistema para manejar grandes volúmenes de datos, integrarse con otros sistemas y proporcionar una detección precisa y oportuna. Además, el diseño e implementación de una solución personalizada permitirá abordar las amenazas más relevantes y específicas del entorno (García-Teodoro et al., 2009). La evaluación del sistema mediante simulaciones de ataques reales es un paso esencial para validar su efectividad y para identificar áreas de mejora.³

³ Stallings, W. (2019). *Cryptography and Network Security: Principles and Practice*. Pearson.

Identificación y Selección de una Plataforma IDS

Selección de una plataforma IDS

Para la identificación y selección de una plataforma IDS, se contempló dos aplicativos el SELKS y el OSSIM donde el primero es una muy buena opción para el análisis de tráfico de red. Al estar basado en suricata ofrece una capacidad fuerte de detección de intrusiones que trabaja con kibana para la observación de datos, este solamente posee un sensor al momento de realizar un escaneo por lo que tarda en completar un análisis de la red. Mientras que el OSSIM se pueden utilizar varios al mismo momento, a destacar también este permite la integración de múltiples fuentes facilitando una visión más amplia y escalable del entorno de seguridad por tal motivo se decidió implementar una arquitectura de gestión de registros y seguridad de la información basada en Rsyslog y AlienVault OSSIM ya que este va más allá del tráfico de red y nos permite tener alertas más contextualizadas de los ataques. Se eligió Rsyslog por su capacidad para centralizar y procesar de manera eficiente grandes volúmenes de registros, mientras que se eligió AlienVault OSSIM por su conjunto completo de características SIEM, incluida la correlación de eventos, el escaneo de vulnerabilidades y la detección de intrusiones. Esta combinación permite la detección proactiva de amenazas, facilita la respuesta a incidentes de seguridad y mejora la postura de seguridad general del sistema.

Plataformas IDS

Los archivos de registro se pueden almacenar en formatos de texto sin formato o incluso en bases de datos u otras plataformas en caso de errores mediante el formato de transporte, marcas de tiempo precisas, acciones de cola de procesamiento y opciones de filtrado en todo el informe.

Adicionalmente, se implementó Alien vault Ossim, es un sistema de gestión de eventos e información de seguridad (SIEM) de código abierto y con numerosas funciones que incluye recopilación, normalización y correlación de eventos. AlienVault OSSIM se compone de los siguientes factores:

- Descubrimiento de activos: Identifica y cataloga todos los activos de una organización.
- Evaluación de vulnerabilidad: Analiza y estima los riesgos de las debilidades en la seguridad de los sistemas de información e informática de una organización.
- Detección de intrusos: Herramienta de seguridad de red que monitoriza el tráfico y los dispositivos en busca de actividades maliciosas conocidas o sospechosas.
- Monitoreo de comportamiento: Seguimiento continuo de actividades normales en la red y los sistemas de una organización.
- Correlación de eventos SIEM: Análisis y relación inmediata de los datos generados por eventos y registros en un entorno de seguridad.⁴



⁴ <https://iberasync.es/gestion-de-vulnerabilidades-con-un-siem-alienvault-ossim/>

⁵ <https://www.it-como-hobby.com/index.php/2017/10/03/instalar-agente-ossim-en-linux/>

Figura 1. Rsyslog - Alientvault Ossim

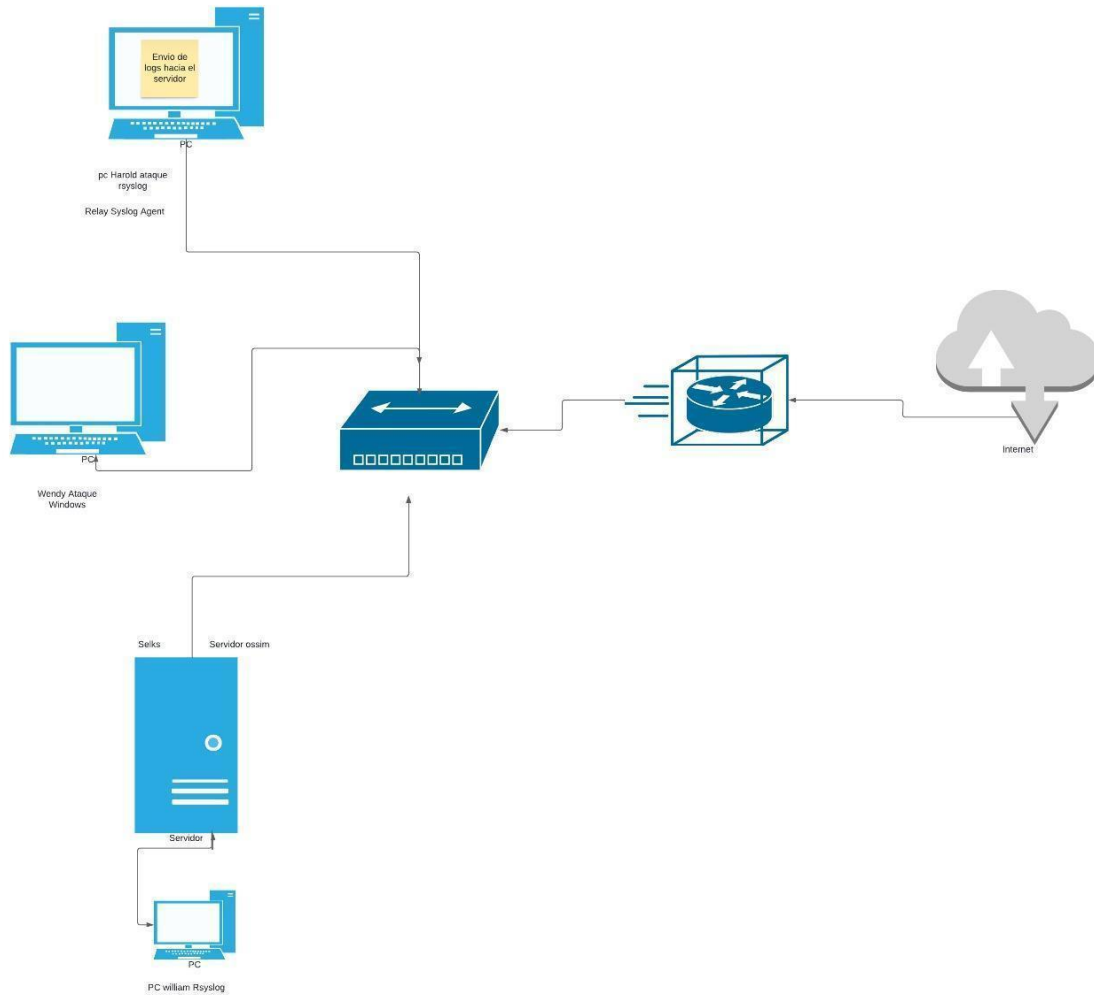
Diseño e implementación de una solución IDS personalizada

Figura 2. Diagrama sistema IDS

- Se crea un entorno de red simulado que replica las características de una infraestructura real.
- Se genera un conjunto variado de logs y registros que simulan actividades normales y ataques cibernéticos comunes.



Figura 3. - Configuración máquina Alienvault Ossim

- Configuramos las herramientas para la ingestión, procesamiento y análisis de los datos generados en el entorno simulado (Alienvault Ossim).⁶
- Se seleccionan las herramientas de análisis de logs y registros adecuados (Rsyslog).

A screenshot of the 'Administrator Account Creation' form. The form has a title 'Administrator Account Creation' and a subtitle 'Create an account to access your AlienVault product.' Below the subtitle, there is a note: '* Asterisks indicate required fields'. The form contains several input fields: 'FULL NAME *', 'USERNAME *' (with 'admin' entered), 'PASSWORD *', 'CONFIRM PASSWORD *', 'E-MAIL *', 'COMPANY NAME', and 'LOCATION'. To the right of the 'LOCATION' field, there is a link that says '→ View Map'. At the bottom of the form, there is a blue button that says 'START USING ALIENVAULT'.

Figura 4. - Creación de usuario siem

⁶AT&T Cybersecurity. (s.f.). USM Appliance Deployment Guide. AT&T Cybersecurity.

- Creamos la cuenta administradora de la plataforma web de ossim para configurar y ver las alertas que nos reporta de lo que les pasa a los equipos de nuestra red.

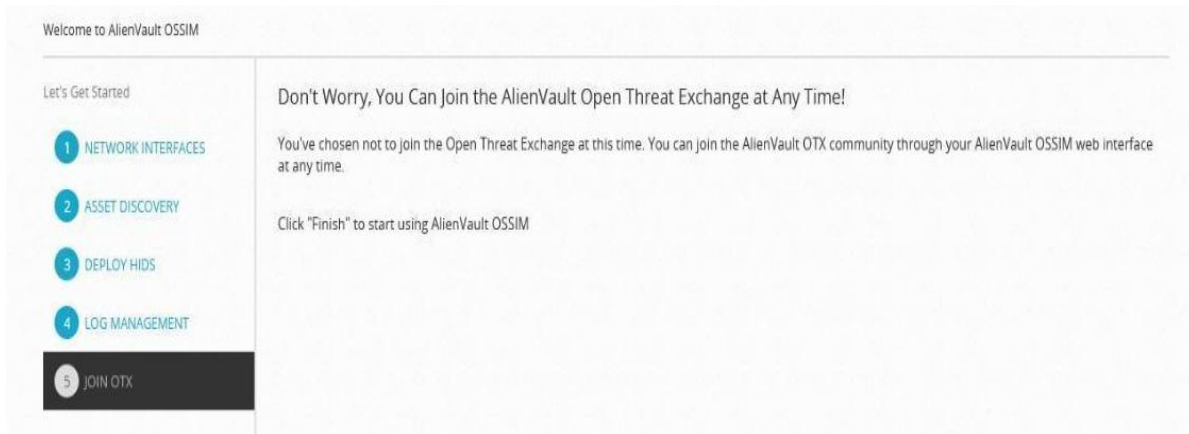


Figura 5. - Introducción plataforma siem

- Identificamos las amenazas cibernéticas más relevantes para el entorno simulado.
- Desarrollamos reglas de detección personalizadas basadas en patrones de comportamiento anómalos e indicadores de compromiso (IoC).
- Utilizar técnicas de análisis de comportamiento para detectar ataques no firmados.

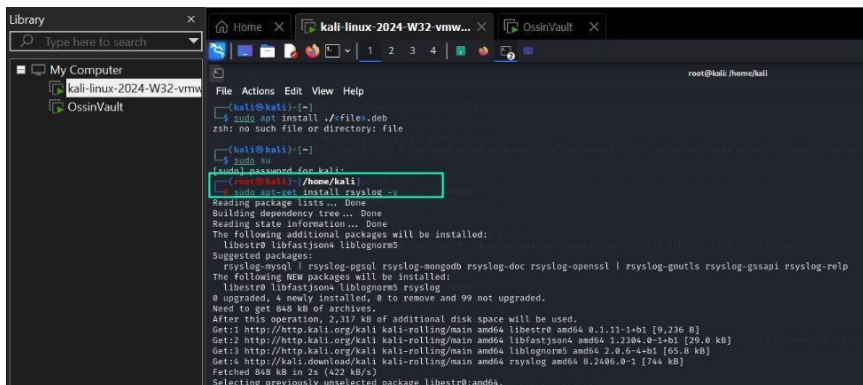
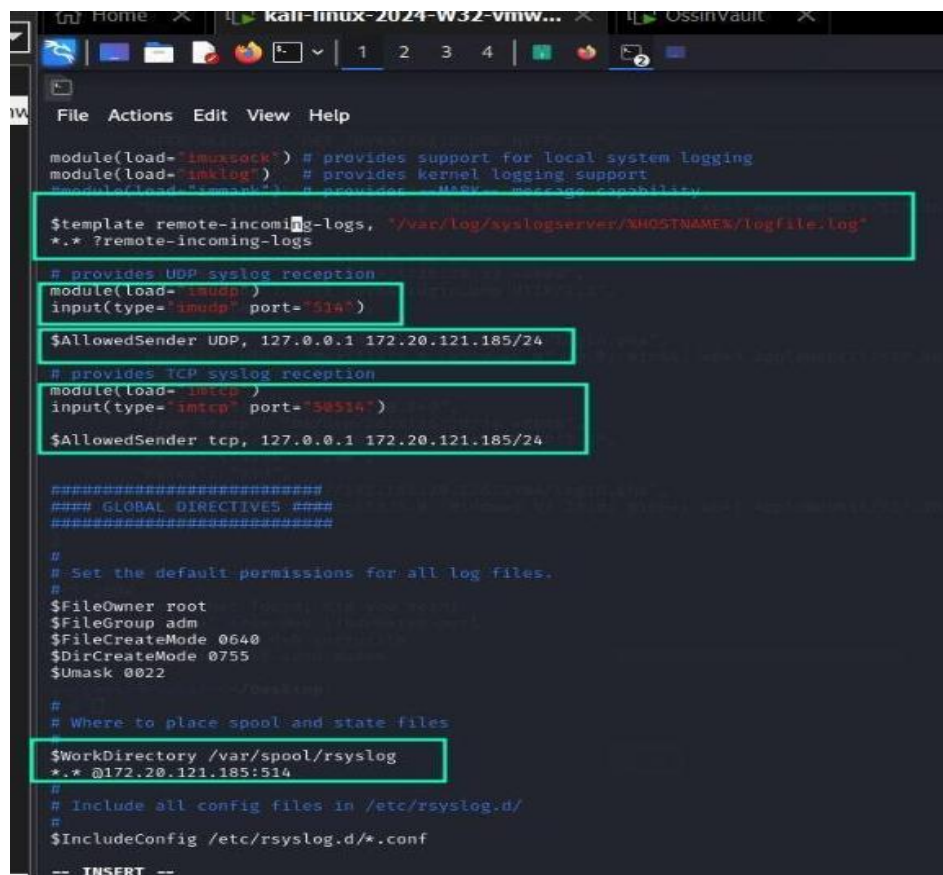


Figura 6. - Actualización de dependencias e instalación Rsyslog

En consola, se cambia de usuario Kali a root para poder instalar el Rsyslog este nos permite registrar lo que le está sucediendo en la máquina y a su vez mandarlo hacia otra máquina que funciona como servidor.



```
module(load="imuxsock") # provides support for local system logging
module(load="imklog") # provides kernel logging support
module(load="immark") # provides MARK message capability

$template remote-incoming-logs, "/var/log/syslogserver/%HOSTNAME%/logfile.log"
*. * ?remote-incoming-logs

# provides UDP syslog reception
module(load="imudp")
input(type="imudp" port="514")

$AllowedSender udp, 127.0.0.1 172.20.121.185/24

# provides TCP syslog reception
module(load="imtcp")
input(type="imtcp" port="514")

$AllowedSender tcp, 127.0.0.1 172.20.121.185/24

#####
#### GLOBAL DIRECTIVES ####
#####

#
# Set the default permissions for all log files.
#
$FileOwner root
$FileGroup adm
$FileCreateMode 0640
$DirCreateMode 0755
$Umask 0022

#
# Where to place spool and state files
#
$WorkDirectory /var/spool/rsyslog
*. * @172.20.121.185:514

#
# Include all config files in /etc/rsyslog.d/
#
$IncludeConfig /etc/rsyslog.d/*.conf

-- INSERT --
```

Figura 7. - Configuración de Rsyslog envío de logs

Como se muestra en la imagen, se accede al archivo de configuración del programa para poder enviar los logs hacia la máquina que funciona como servidor, se debe poner la dirección ip del equipo que se encarga de recibir las alertas, se pone los dos protocolos de transmisión de red que más se utilizan que son udp y tcp.⁷

⁷<https://cybersecurity.att.com/documentation/resources/pdf/usm-appliance-deployment-guide.pdf>

```
(root@kali)-[/home/kali]
# apt install ufw
The following packages were automatically installed and are no longer required:
  rwho rwhod
Use 'sudo apt autoremove' to remove them.

Installing:
  ufw

Summary:
  Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 22
  Download size: 168 kB
  Space needed: 880 kB / 54.3 GB available

Get:1 http://kali.download/kali kali-rolling/main amd64 ufw all 0.36.2-6 [168 kB]
Fetched 168 kB in 1s (182 kB/s)
Preconfiguring packages ...
Selecting previously unselected package ufw.
(Reading database ... 397937 files and directories currently installed.)
Preparing to unpack .../archives/ufw_0.36.2-6_all.deb ...
Unpacking ufw (0.36.2-6) ...
Setting up ufw (0.36.2-6) ...

Creating config file /etc/ufw/before.rules with new version

Creating config file /etc/ufw/before6.rules with new version

Creating config file /etc/ufw/after.rules with new version

Creating config file /etc/ufw/after6.rules with new version
update-rc.d: We have no instructions for the ufw init script.
update-rc.d: It looks like a non-network service, we enable it.
Created symlink '/etc/systemd/system/multi-user.target.wants/ufw.service' -> '/usr/lib/systemd/system/ufw.service'.
Processing triggers for kali-menu (2024.3.1) ...
Processing triggers for rsyslog (8.2406.0-1) ...

Progress: [ 80% ]
```

Figura 8. - Instalación de firewall

Se instala un firewall para poder tener control de la máquina a través de reglas y políticas predeterminadas para el tráfico entrante y saliente con comandos simples.

Ayuda a mejorar la seguridad del sistema al permitir o denegar conexiones específicas.

```
(root@kali)-[/home/kali]
# ufw allow 514/udp
Rules updated
Rules updated (v6)

(root@kali)-[/home/kali]
# ufw allow 50514/udp
Rules updated
Rules updated (v6)
```

Figura 9. - Actualización de reglas udp y tcp

Se actualiza la regla que tiene el firewall para transmitir conexión por el puerto 514 con el protocolo udp. También para el puerto 50514 permitiendo comunicación con otra máquina.⁸

```
(root@kali)~# systemctl status rsyslog
● rsyslog.service - System Logging Service
   Loaded: loaded (/usr/lib/systemd/system/rsyslog.service; enabled; preset: enabled)
   Active: active (running) since Fri 2024-09-13 21:49:54 EDT; 52s ago
     Invocation: 850fb71883e9459d96a4d758e3863c49
   TriggeredBy: ● syslog.socket
     Docs: man:rsyslogd(8)
           man:rsyslog.conf(5)
           https://www.rsyslog.com/doc/
   Main PID: 68662 (rsyslogd)
     Tasks: 10 (limit: 19089)
    Memory: 221.2M (peak: 221.5M)
       CPU: 53.163s
    CGroup: /system.slice/rsyslog.service
           └─68662 /usr/sbin/rsyslogd -n -iNONE

Sep 13 21:49:54 kali systemd[1]: Starting rsyslog.service - System Logging Service...
Sep 13 21:49:54 kali rsyslogd[68662]: imuxsock: Acquired UNIX socket '/run/systemd/journal/syslog' (fd 3) from systemd. [v8.2406.0]
Sep 13 21:49:54 kali rsyslogd[68662]: [origin software="rsyslogd" swVersion="8.2406.0" x-pid="68662" x-info="https://www.rsyslog.com"] start
Sep 13 21:49:54 kali systemd[1]: Started rsyslog.service - System Logging Service.
```

Figura 10. - Comprobación del estado de Rsyslog

Se realiza comprobación del estado del Rsyslog, observando que el servicio se encuentre activo y funcionando correctamente.⁹

```
Starting shell
alienvault:~# tcpdump -i eth0 udp port 514
tcpdump: verbose output suppressed, use -v or -vv for full protocol decode
listening on eth0, link-type EN10MB (Ethernet), capture size 262144 bytes
21:00:50.336888 IP 172.30.121.186.61794 > alienvault.alienvault.syslog: SYSLOG daemon.info, length: 89
21:00:50.337279 IP 172.30.121.186.61794 > alienvault.alienvault.syslog: SYSLOG syslog.info, length: 153
21:00:50.337300 IP 172.30.121.186.61794 > alienvault.alienvault.syslog: SYSLOG daemon.info, length: 79
21:00:50.337306 IP 172.30.121.186.61794 > alienvault.alienvault.syslog: SYSLOG daemon.info, length: 86
21:00:50.337311 IP 172.30.121.186.61794 > alienvault.alienvault.syslog: SYSLOG daemon.info, length: 89
21:00:50.340613 IP 172.30.121.186.61794 > alienvault.alienvault.syslog: SYSLOG syslog.info, length: 129
21:00:50.340663 IP 172.30.121.186.61794 > alienvault.alienvault.syslog: SYSLOG syslog.info, length: 137
21:00:50.340674 IP 172.30.121.186.61794 > alienvault.alienvault.syslog: SYSLOG daemon.info, length: 86
```

Figura 11. - Testeo de paquetes y comprobación de puerto 514 con la consola del Alienvault

Ossim, se puede observar la escucha de paquetes que hay en el segmento de red en la que se encuentra conectado por el puerto 514.

⁸ Stamus Networks. (2022). SELKS SSP White Paper. Stamus Networks.

⁹ [https://www.stamus-networks.com/hubfs/Library/Documents%20\(PDFs\)/StamusNetworks-WP-SELKS-SSP-102022-1.pdf](https://www.stamus-networks.com/hubfs/Library/Documents%20(PDFs)/StamusNetworks-WP-SELKS-SSP-102022-1.pdf)


```
dell-equallogic.sql      mikrotik-router.sql.gz  sangfor-iam.sql          zscaler.sql
dell-force.sql           mobileiron-sentry.sql   sangfor.sql              zyxel-firewall.sql
dell-idrac.sql           modsecurity.sql.gz      sap.sql
dell-secureworks.sql.gz  monit.sql               saqara-ca.sql.gz
dell-switch.sql          moodle.sql               scom-nxlog.sql.gz
alienvault:/usr/share/doc/ossim-mysql/contrib/plugins# gunzip ssh.sql.gz
gzip: ssh.sql.gz: No such file or directory
alienvault:/usr/share/doc/ossim-mysql/contrib/plugins# gunzip ssh.sql.gz
gzip: ssh.sql.gz: No such file or directory
alienvault:/usr/share/doc/ossim-mysql/contrib/plugins# gunzip ssh.sql
gzip: ssh.sql: unknown suffix -- ignored
alienvault:/usr/share/doc/ossim-mysql/contrib/plugins# cp ssh.sql debianssh.sql_
```

Figura 12. - Búsqueda y descarga de plugin

Se busca y descarga el plugin que deseamos para luego descomprimirlo, para este caso es un complemento que nos permite registrar ataques de tipo conexión remota ssh.

```
-- ssh
-- plugin_id: 9001

DELETE FROM plugin WHERE id = "9001";
DELETE FROM plugin_sid WHERE plugin_id = "9001";

INSERT IGNORE INTO plugin (id, type, name, description, vendor, product_type) VALUES (4003, 1, 'ssh', 'SSHd: Secure Shell daemon', 'OpenBSD', 23);

INSERT IGNORE INTO plugin_sid (plugin_id, sid, category_id, subcategory_id, class_id, name, priority, reliability) VALUES
(4003, 1, 2, 25, NULL, 'SSHd: Failed password', 3, 2),
(4003, 2, 2, 25, NULL, 'SSHd: Failed publickey', 2, 2),
(4003, 3, 2, 25, NULL, 'SSHd: Invalid user', 3, 2),
(4003, 4, 2, 25, NULL, 'SSHd: Illegal user', 3, 2)
```

Figura 13. - Modificación de query base de datos OSSIM

Se realizan modificaciones al plugin para que el ossim registre todos los logs de tipo ssh en la base de datos, se reemplaza el id para que no entre conflicto con otro plugin.

```
alienvault:/usr/share/doc/ossim-mysql/contrib/plugins# ossim-db < debianssh.sql
alienvault:/usr/share/doc/ossim-mysql/contrib/plugins# ossim-db
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 6642
Server version: 10.4.24-MariaDB-1:10.4.24+maria~stretch mariadb.org binary distribution

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [alienvault]> select * from plugin where id = 9001;
+-----+-----+-----+-----+-----+-----+-----+
| ctx   | id   | type | name          | description          | product_type | vendor |
+-----+-----+-----+-----+-----+-----+-----+
|       | 9001 | 1    | DEBIANPRUEBssh | DEBIANSSHd: Secure Shell daemon | 23          | OpenBSD |
+-----+-----+-----+-----+-----+-----+-----+
1 row in set (0.001 sec)

MariaDB [alienvault]>
```

Figura 14. - Consulta de la base de datos del OSSIM

Verificamos que el plugin esté guardado correctamente en la base de datos del ossim.



Figura 15. - actualización de cambios de eventos

Hacemos una configuración para instalar y actualizar nuevos repositorios para la máquina.

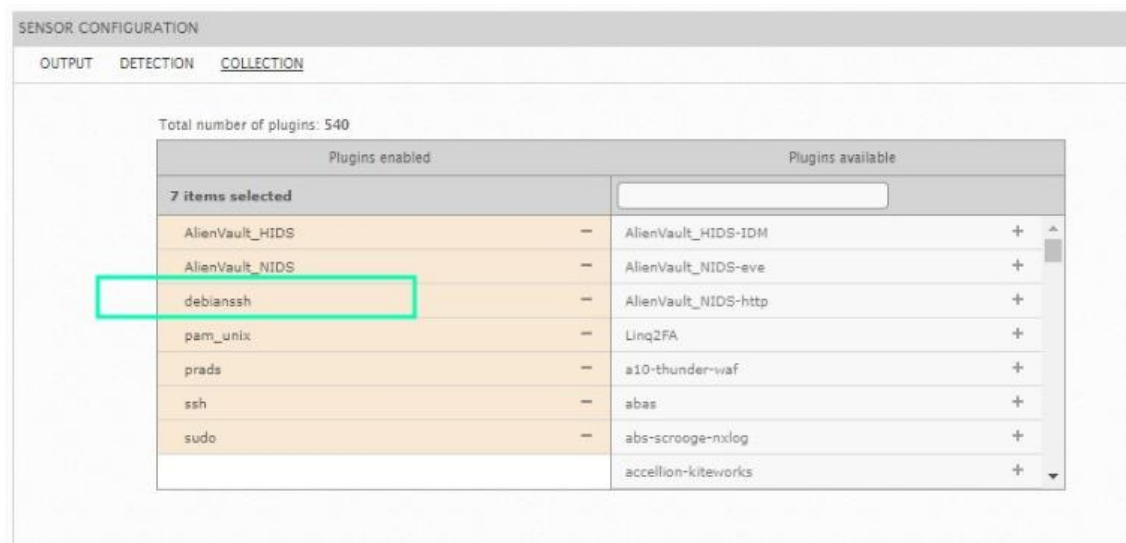
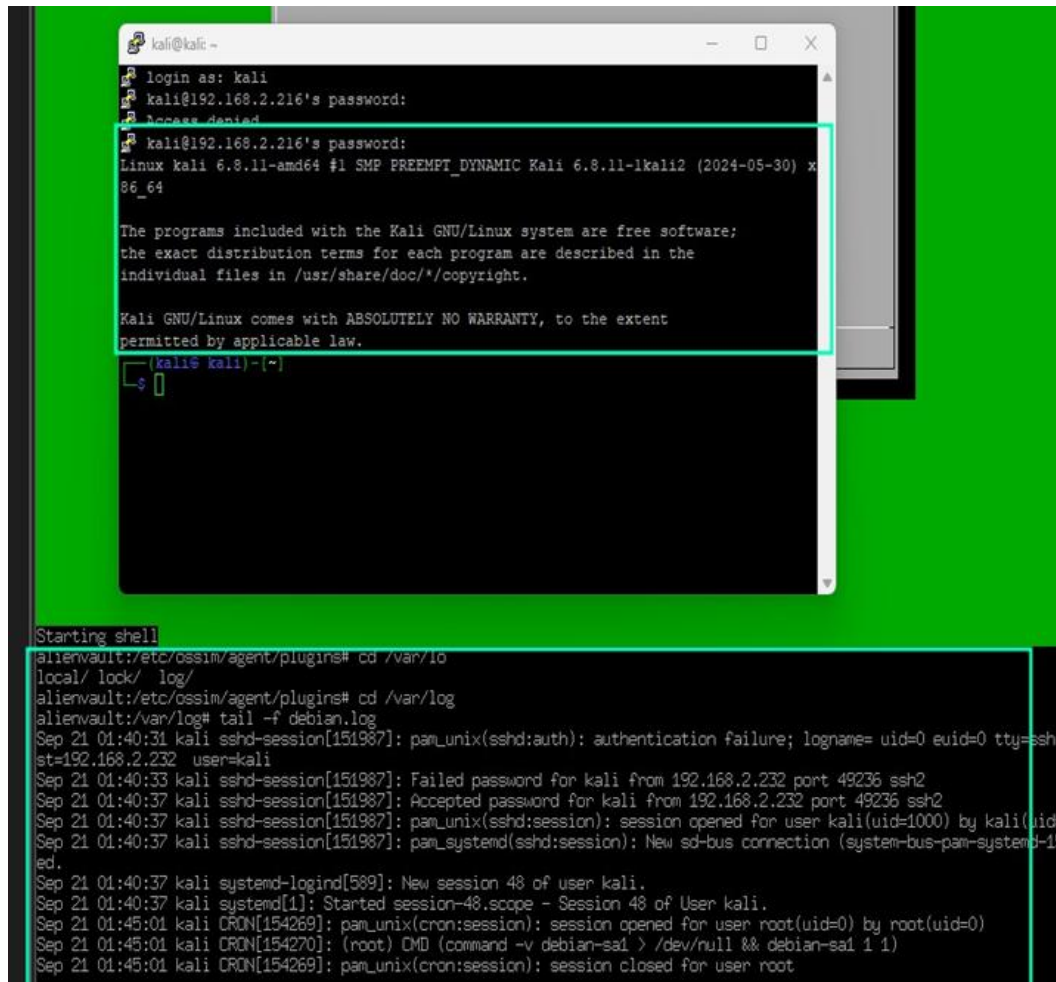


Figura 16. - Configuración

Verificamos el plugin en la plataforma web en recuadro de habilitado.

Pruebas de simulación



The image shows a terminal window with a black background and white text. The top part of the terminal shows a login attempt for 'kali' at IP 192.168.2.216. The password is entered, but the login is denied. The terminal then displays the Kali Linux version information (6.8.11-amd64) and the license information. Below this, the terminal shows the command 'Starting shell' and the execution of 'cd /var/log'. The bottom part of the terminal shows the output of 'tail -f debian.log', which displays a series of system logs including authentication failures, session openings, and cron jobs.

```
kali@kali: ~  
login as: kali  
kali@192.168.2.216's password:  
Access denied  
kali@192.168.2.216's password:  
Linux kali 6.8.11-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.8.11-1kali2 (2024-05-30) x86_64  
  
The programs included with the Kali GNU/Linux system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Kali GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent  
permitted by applicable law.  
kali@kali: ~  
$  
  
Starting shell  
alienvault:/etc/ossim/agent/plugins# cd /var/log  
local/ look/ log/  
alienvault:/etc/ossim/agent/plugins# cd /var/log  
alienvault:/var/log# tail -f debian.log  
Sep 21 01:40:31 kali sshd-session[151987]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh  
st=192.168.2.232 user=kali  
Sep 21 01:40:33 kali sshd-session[151987]: Failed password for kali from 192.168.2.232 port 49236 ssh2  
Sep 21 01:40:37 kali sshd-session[151987]: Accepted password for kali from 192.168.2.232 port 49236 ssh2  
Sep 21 01:40:37 kali sshd-session[151987]: pam_unix(sshd:session): session opened for user kali(uid=1000) by kali(uid=1000)  
Sep 21 01:40:37 kali sshd-session[151987]: pam_systemd(sshd:session): New sd-bus connection (system-bus-pam-systemd-151987)  
ed.  
Sep 21 01:40:37 kali systemd-logind[589]: New session 48 of user kali.  
Sep 21 01:40:37 kali systemd[1]: Started session-48.scope - Session 48 of User kali.  
Sep 21 01:45:01 kali CRON[154269]: pam_unix(cron:session): session opened for user root(uid=0) by root(uid=0)  
Sep 21 01:45:01 kali CRON[154270]: (root) CMD (command -v debian-sa1 > /dev/null && debian-sa1 1 1)  
Sep 21 01:45:01 kali CRON[154269]: pam_unix(cron:session): session closed for user root
```

Figura 17. - Registro de eventos de logs rsyslog

Con el programa putty realizamos pruebas de conexión ssh para verificar que el Rsyslog envíe los logs de la máquina cliente a la máquina servidor.¹⁰

¹⁰ Rsyslog. (s.f.). Rsyslog Configuration Guide. Rsyslog.

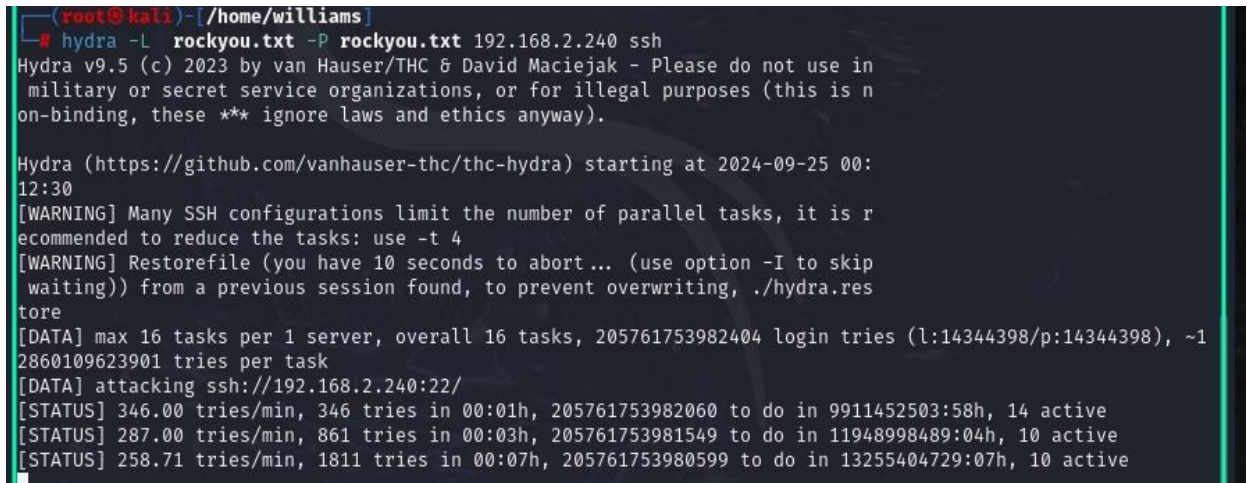


Figura 18. - Prueba de ataque por diccionario

Desde la máquina agresora realizamos un ataque con un software llamado hydra y con un diccionario llamado rockyou.txt donde este tiene las credenciales para poder acceder por el método de ssh.

PAUSE Done. [0 new rows]							
DATE	EVENT NAME	RISK	DATA SOURCE	SENSOR	OTX	SOURCE IP	DEST IP
2024-09-21 01:22:22	SSHD: Server terminated	0	DEBIANPRUEBAssh	alienvault	N/A	0.0.0.0	0.0.0.0:22
2024-09-21 01:22:22	SSHD: Server listening	0	DEBIANPRUEBAssh	alienvault	N/A	::	0.0.0.0:22
2024-09-21 01:22:22	SSHD: Server listening	0	DEBIANPRUEBAssh	alienvault	N/A	0.0.0.0	0.0.0.0:22
2024-09-20 22:21:03	Syslog: syslog entry	0	syslog	alienvault	N/A	0.0.0.0	0.0.0.0
2024-09-20 22:21:03	Syslog: syslog entry	0	syslog	alienvault	N/A	0.0.0.0	0.0.0.0
2024-09-20 22:21:03	Syslog: syslog entry	0	syslog	alienvault	N/A	0.0.0.0	0.0.0.0

Figura 19. - Plataforma siem eventos de seguridad

En la plataforma en la sección de análisis podemos ver las alertas que nos reporta Rsyslog de los logs que han sido notificados.¹¹

Configuración, operación y resolución de problemas comunes del IDS

Manual de Usuario del IDS OSSIM

Índice

- 1. Introducción**
 - 2. Requisitos Previos**
 - 3. Instalación del IDS OSSIM**
 - 4. Configuración Inicial**
 - 5. Configuración del Sensor IDS**
 - 6. Monitorización y Operación del IDS**
 - 7. Resolución de Problemas Comunes**
 - 8. Mantenimiento del IDS**
-

Introducción

El sistema **OSSIM** de AT & T AlienVault es una solución completa de gestión de eventos e información de seguridad (SIEM) que incluye la funcionalidad de detección de intrusiones (IDS). Este manual tiene como objetivo guiar a los usuarios a través de la configuración y operación del sistema, asegurando que el IDS funcione correctamente y que los usuarios puedan solucionar problemas comunes.

Requisitos Previos

Antes de comenzar, asegúrate de tener lo siguiente:

- 1. VM con OSSIM instalado y en funcionamiento.**
- 2. Acceso administrativo** a la consola de administración web de OSSIM.
- 3. Redes configuradas adecuadamente** para que OSSIM pueda comunicarse con los sensores y otros dispositivos.

¹¹ <https://www.rsyslog.com/doc/configuration/index.html>

Instalación del IDS OSSIM

Paso 1: Descargar e instalar OSSIM

1. **Descargar ISO:** Descarga la ISO de OSSIM desde el sitio oficial de **AlienVault** o **AT&T Cybersecurity**.
2. **Crear VM:** Configura una máquina virtual con al menos 8GB de RAM, 2 CPUs y 100GB de almacenamiento. Asigna una IP estática o dinámica según tu infraestructura de red.
3. **Instalar OSSIM:** Sigue las instrucciones en pantalla para la instalación de OSSIM en la máquina virtual.
4. **Primer acceso:** Tras la instalación, accede a la interfaz web de administración de OSSIM (<https://<IP del servidor>:80>) usando las credenciales creadas durante la instalación.

Configuración Inicial

Paso 2: Acceso a la interfaz web de OSSIM

En un navegador web, accede a la interfaz de OSSIM:

1. https://<IP_del_servidor_OSSIM>
2. Inicia sesión con el usuario admin y la contraseña que configuraste durante la instalación.

Paso 3: Configuración de red del servidor OSSIM

1. Asegúrate de que la configuración de red del servidor OSSIM es la correcta:
 - a. Configura una **IP estática** en tu servidor si no lo hiciste durante la instalación.
 - b. Verifica que OSSIM pueda comunicarse con los dispositivos en la red.

Paso 4: Actualización del sistema OSSIM

Desde la consola de administración, actualiza OSSIM para asegurarte de que todo el software esté en su última versión. Usa los siguientes comandos si prefieres hacerlo desde la terminal:

1. `sudo apt update`
2. `sudo apt upgrade`

Configuración del Sensor IDS

Paso 5: Activar el sensor IDS en OSSIM

1. Navega a la pestaña "**Configuración**" en la interfaz web de OSSIM.
2. Dirígete a "**Sensores**".

3. Selecciona el servidor OSSIM principal y habilita el sensor **Suricata**, que actúa como el motor de IDS.
4. Define las redes que deseas monitorear, agregando los rangos de IP relevantes en el campo **"Redes monitorizadas"**.
5. Guarda la configuración.

Paso 6: Configuración de las firmas IDS

1. Navega a la sección **"Policies"** (Políticas) en la interfaz de OSSIM.
2. Activa o desactiva las reglas del IDS para tus necesidades específicas:
 - a. Puedes habilitar firmas de detección de intrusiones para tráfico malicioso conocido.

Si necesitas personalizar las reglas, editarlas directamente en el archivo de configuración de Suricata:

3. `sudo nano /etc/suricata/suricata.yaml`

Paso 7: Verificación de funcionamiento del IDS

1. En la pestaña **"Security Events"**, puedes ver los eventos generados por Suricata.
2. Usa herramientas como **Nmap** o scripts de prueba de ataques (dentro de entornos controlados) para verificar que el IDS detecta correctamente intentos de intrusión.

Monitorización y Operación del IDS

Paso 8: Supervisión de Eventos de Seguridad

1. Ve a **"Security Events"** para ver todos los eventos de seguridad registrados por el IDS.
2. Utiliza los filtros para ajustar la visualización según el tipo de evento, fuente de IP o severidad.
3. Analiza los eventos críticos y toma acciones preventivas o correctivas según sea necesario.

Paso 9: Generar Reportes

1. En la sección **"Reports"**, puedes generar reportes personalizados sobre la actividad del IDS.
2. Configura reportes automáticos que te envíen un resumen de los eventos en intervalos definidos (diario, semanal, etc.).

Resolución de Problemas Comunes

Problema 1: El IDS no está detectando tráfico

- **Solución:** Verifica la configuración de red para asegurarte de que el sensor Suricata esté monitoreando las interfaces correctas.

1. Asegúrate de que la red monitorizada esté correctamente configurada en "**Sensores**".

Revisa el archivo de configuración de Suricata para asegurarte de que las reglas están cargadas:

2. `sudo suricata -T -c /etc/suricata/suricata.yaml`

Problema 2: Falta de eventos en la consola web

Solución: Asegúrate de que los servicios de OSSIM y Suricata estén en ejecución. Reinicia los servicios:

- `sudo systemctl restart suricata`
- `sudo systemctl restart ossim-server`

Problema 3: El tráfico legítimo es detectado como malicioso (falsos positivos)

- **Solución:** Ajusta las reglas IDS para reducir falsos positivos:

1. Desactiva las reglas que generan falsos positivos en "**Policies**".

2. Agrega excepciones o reglas personalizadas para filtrar este tráfico.

Problema 4: Rsyslog no está enviando logs al OSSIM

- **Solución:** Revisa la configuración de Rsyslog en el cliente y servidor para asegurar de que están correctamente configurados.

Problema 5: Cambio de contraseña de la plataforma web OSSIM**Solución:**

1. dirigirse al menú de alienvault OSSIM
2. luego ir a system preferences
3. después seleccione change password
4. ir a donde dice reset UI admin password
5. él OSSIM te dará una contraseña temporal para poder ingresar a la plataforma web
6. luego iniciar sesión con el usuario asignado y pones la contraseña temporal
7. cambias la contraseña a tus preferencias
8. se puede iniciar sesión normalmente

Mantenimiento del IDS**Paso 10: Actualización de reglas IDS**

Es importante mantener actualizadas las reglas del IDS para detectar nuevas amenazas. En OSSIM, las actualizaciones de reglas se pueden realizar manualmente o automáticamente:

1. `sudo apt-get update && sudo apt-get upgrade`

Paso 11: Copias de seguridad

1. Realiza copias de seguridad periódicas de la configuración y la base de datos del OSSIM para evitar la pérdida de datos ante un fallo del sistema.
2. Usa herramientas como mysqldump para hacer backup de la base de datos de eventos.

Conclusiones

- La implementación del sistema de detección de intrusiones (IDS) usando logs y combinando Rsyslog con AlienVault OSSIM fue efectiva para detectar amenazas en tiempo real en un entorno simulado. Gracias a esta integración, el sistema pudo lanzar alertas de forma rápida y precisa, lo que ayudó a reducir el tiempo de respuesta ante incidentes y a mejorar la seguridad general de la red.
- Las pruebas de simulación, que incluyeron ataques de fuerza bruta al protocolo SSH, confirmaron que el IDS es capaz de detectar comportamientos anómalos, priorizar respuestas y mitigar riesgos de seguridad. Un gran logro de esta implementación fue la capacidad de centralizar y procesar grandes volúmenes de registros mediante reglas de detección personalizadas. Esto permitió detectar tanto ataques basados en patrones conocidos como aquellos que no lo son, ampliando considerablemente el rango de amenazas que el sistema pudo mitigar.
- AlienVault OSSIM, aportó funcionalidades clave como la correlación de eventos, la evaluación de vulnerabilidades y el descubrimiento de activos, convirtiéndolo en una plataforma integral y centralizada para la gestión de la seguridad. Estas funcionalidades no solo facilitaron la detección y respuesta ante incidentes, sino que también permitieron una evaluación continua de la infraestructura crítica, ayudando a mantener una postura de seguridad proactiva.

- El uso de Rsyslog para la gestión de registros fue especialmente efectivo al manejar grandes volúmenes de logs y enviarlos centralizadamente para su análisis y correlación en OSSIM. Esto fue esencial para detectar intentos de intrusión a nivel de red y sistemas.

Recomendaciones

- Actualizar regularmente las reglas de detección y los plugins para mantener el sistema eficaz contra las amenazas emergentes.
- Considerar la integración del IDS con otros sistemas de seguridad para crear una solución de seguridad más completa y coordinada.
- Realizar un seguimiento regular del rendimiento del sistema y ajustar la configuración según sea necesario para optimizar la eficacia y reducir los falsos positivos.

. Referencia

1. Whitman, M. E., & Mattord, H. J. (2017). Principles of Information Security (6th ed.). Cengage Learning.
2. <https://latam.kaspersky.com/about/press-releases/nueva-epidemia-el-phishing-se-sextuplico-en-america-latina-con-el-reinicio-de-la-actividad-economica-y-el-apoyo-de-la-ia>
3. Stallings, W. (2019). Cryptography and Network Security: Principles and Practice. Pearson.
4. <https://iberasync.es/gestion-de-vulnerabilidades-con-un-siem-alienvault-ossim/>
5. <https://www.it-como-hobby.com/index.php/2017/10/03/instalar-agente-ossim-en-linux/>
6. AT&T Cybersecurity. (s.f.). USM Appliance Deployment Guide. AT&T Cybersecurity.
7. <https://cybersecurity.att.com/documentation/resources/pdf/usm-appliance-deployment-guide.pdf>

8. Stamus Networks. (2022). SELKS SSP White Paper. Stamus Networks.
9. [https://www.stamus-networks.com/hubfs/Library/Documents%20\(PDFs\)/StamusNetworks-WP-SELKS-SSP-102022-1.pdf](https://www.stamus-networks.com/hubfs/Library/Documents%20(PDFs)/StamusNetworks-WP-SELKS-SSP-102022-1.pdf)
10. Rsyslog. (s.f.). Rsyslog Configuration Guide. Rsyslog.
11. <https://www.rsyslog.com/doc/configuration/index.html>

Apéndices

Configuración Básica de Rsyslog para Envío de Logs

- Agregar las siguientes líneas al archivo
`/etc/rsyslog.conf`
- Enviar todos los logs a un servidor remoto usando UDP
`@192.168.1.100:514`
- Enviar todos los logs a un servidor remoto usando TCP
`@@192.168.1.100:514`
- Reiniciar el servicio Rsyslog después de realizar cambios
`sudo systemctl restart rsyslog`

Nota: En **192.168.1.100** reemplace con la dirección IP de su servidor OSSIM.